INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — PaketPro 3000 Sürümü · Paketleme Makinesi

Tüm laboratuvarlar deck'in işlenmiş örnek makinesi PaketPro 3000'e uyarlanmıştır: sıcak çene + kesme bıçağı · ışık perdesi · 16 varlık + 5 dış bağlantı · internete açık uzak bakım modülü.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

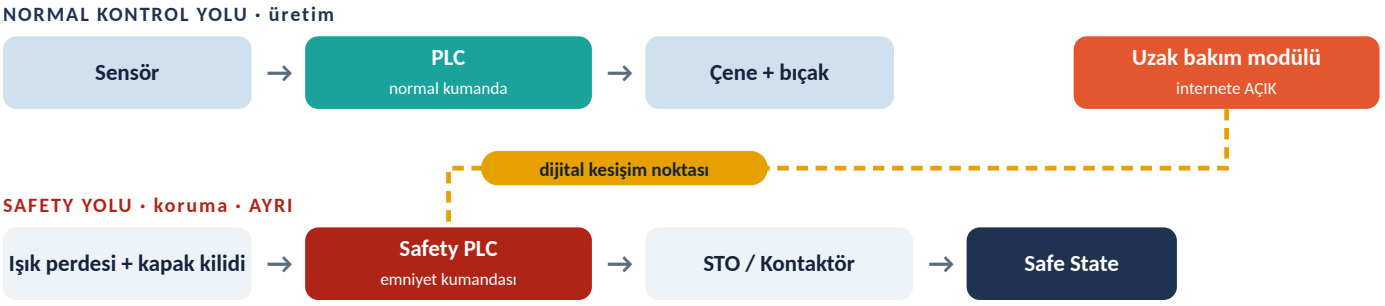
LABORATUVAR 1 · PAKETPRO 3000 · Paketleme Makinesi

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad | Grup | Tarih

PaketPro bağlamı: Sıcak yapıştırma çenesi ve film kesme bıçağı el/parmak için ciddi tehlikedir; koruma **ışık perdesi + kapak kilidi → Safety PLC → STO** zinciridir. Ve bu makinenin **internete açık bir uzak bakım modülü** vardır — sorular oraya gidecek.



Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

Sıcak yapıştırma çenesi (yanık, ezilme) ve film kesme bıçağı (kesilme, parmak/el kaybı). Operatör paket besleme, film değiştirme veya sıkışma gidermede elini çalışma bölgesine uzatır; beklenmedik hareketle el/parmak ağır yaralanır.

2 Safety function (emniyet fonksiyonu) hangisidir?

Işık perdesi ve kapak kilidi ile tehlikeli bölgeye giriş algılanınca çene ve bıçağı durdurma (güvenli durdurma): Işık perdesi + kapak kilidi → Safety PLC → STO/Kontaktör → Safe State.

3 Safety-related control system nerede? Şemada işaretleyin.

Alt satırdaki Safety yolu: Işık perdesi + kapak kilidi (girdi), Safety PLC (mantık), STO/Kontaktör (çıktı). Şemada bu üç kutu birlikte çevrelenir; Sensör → PLC → Çene + bıçak hattı ve uzak bakım modülü bunun dışındadır.

4 Normal PLC ile Safety PLC farkı nedir?

Normal PLC üretimi yönetir (sıra, hız, sıcaklık, kesim); arızası üretim kaybıdır. Safety PLC eli korur: çift kanallı, kendini sürekli kontrol eder, PLr/SIL ile doğrulanmıştır, arızada güvenli duruma gider; programı ayrı korunur ve değişikliği yeniden doğrulama gerektirir.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

PLr/SIL, emniyet fonksiyonunun tehlikeli arıza olasılığını riske göre sınırlar. Çene/bıçakta yaralanma ağır ve geri dönüşsüz olduğu için ışık perdesi + kapak kilidi zinciri yüksek güvenilirlik ister; bu güvenilirlik doğru konfigürasyona (parametre, yazılım) bağlıdır.

6 Safe state (güvenli durum) nedir?

Çene ve bıçağın hareket etmediği, enerjinin kesildiği (STO), kontaktörün açık olduğu durum; yeniden başlatma yalnızca bilinçli reset ile olur. Arıza, enerji veya komut kaybında makine bu duruma geçer (fail-safe).

7 Safety function hangi dijital bağımlılıklara sahip?

Safety PLC programı/konfigürasyonu ve ışık perdesi parametreleri, firmware ve kütüphaneleri, mühendislik/servis erişimi, internete açık uzak bakım modülü ve hesapları (admin/admin), safety haberleşmesi, yama/güncelleme süreci, yedek ve doğrulama dosyaları.

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

'Dijital kesişim noktası'ndan: internete açık uzak bakım modülü → Safety PLC bağlantısı. Modül ele geçirilirse ışık perdesi parametreleri veya kapak kilidi mantığı değiştirilir, çene/bıçak açık bölgede çalışır ve operatörün eli korumasız kalır.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · PAKETPRO 3000 · Paketleme Makinesi

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

Üretim PLC · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · motor sürücüleri · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Üretim bölgesi: Üretim PLC, HMI, motor sürücüleri. Emniyet bölgesi: Emniyet PLC'si (ışık perdesi/kapak kilidi zinciri). Bakım/DMZ bölgesi: uzak bakım modülü (jump server arkasında, kişisel hesapla). Güvensiz/dış bölge: bulut telemetri, Wi-Fi AP, USB portları (kilitli, kontrollü kapıdan). admin/admin hesabı kaldırılır.

2. Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Bakım/DMZ bölgesine düşer ve bugünkü hâliyle orada kalamaz: internete doğrudan açık, admin/admin ile korunuyor ve Safety PLC'ye giden yola yakın. Kapatılır; jump server + VPN + MFA arkasına alınır, varsayılan kapalı olur, safety bölgesine erişimi kesilir.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Güvensiz/dış ↔ Bakım DMZ, DMZ ↔ Üretim ve Üretim ↔ Emniyet geçişleri. Her geçişte: güvenlik duvarıyla yalnızca izinli protokol/port/yön (varsayılan reddet), MFA'lı kişisel kimlik, jump server, oturum kaydı. Emniyet geçişinde yalnız sınırlı tanı; HMI port 80 web arayüzü kapatılır veya şifrelenir.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server: modül bugün doğrudan açık; tek ve denetlenen giriş noktası, oturum izlenip kaydedilir.
Tünel?	Açık / VPN	VPN: şifreli, kimliği doğrulanmış kanal; internete açık servis doğrudan saldırıya açıktır.
Kimlik?	Parola / MFA	MFA: admin/admin gibi zayıf veya çalınan parola tek başına yetmez.
Hesap?	Paylaşılan / Kişisel	Kişisel: izlenebilirlik ve yetki ayrımı; paylaşılan admin/admin hesabı kaldırılır.
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı: olay incelemesi, kanıt ve CRA bildirimi için gerekli.
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı: yalnız onaylı bakım penceresinde süreli açılır; saldırı yüzeyi küçülür.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · PAKETPRO 3000 · Paketleme Makinesi

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad | Grup | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

PaketPro'nun kapıları (ipucu)

İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: çene/bıçakta el-parmak yaralanması, sıkışma.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Saldırgan: internete açık uzak bakım modülü + admin/admin → ışık perdesi/kapak kilidi parametrelerini değiştirir → koruma devre dışı → çene/bıçakta operatörün eli yaralanır.	**3**	**3**	**2**	**18**	**Kritik**
Saldırgan: kilitsiz USB → PLC'ye kötü amaçlı program yükler → çene/bıçak beklenmedik çalışır → bakımdaki personel yaralanır.	**2**	**3**	**1**	**6**	**Orta S=3: öne alındı**
Saldırgan: Wi-Fi AP (karton parola) → HMI port 80 → üretim parametreleri değişir → ürün kaybı, plansız duruş.	**3**	**1**	**2**	**6**	**Orta**

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   Senaryo 1 (skor 18, Kritik): internete açık modül ve admin/admin ile uzaktaki bir saldırgan ışık perdesi/kapak kilidi zincirini bozabilir; sonuç doğrudan operatörün elinde çene/bıçak yaralanmasıdır (S=3) ve erişim yolu zaten açık.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, Senaryo 2: S=3 ama E=1 olduğu için skor 6 (Orta) kaldı. Risk Register'da 'S=3' bayrağıyla işaretler, skordan bağımsız olarak listenin üstüne alır ve emniyet bulgusu olarak ayrı raporlarım; USB kilidi ve yazma kısıtı kapanana kadar izlenir.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · PAKETPRO 3000 · Paketleme Makinesi

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad	Grup	Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İpucu: uzak bakım modülü bugün internete DOĞRUDAN açık.

Servis firması internetten uzak bakım modülüne doğrudan bağlanıyor; modül internete açık, tek paylaşılan admin/admin hesabı, tek faktör parola, oturum kaydı yok. Modül üretim ve Safety PLC ile aynı ağda, bölge ayrımı yok.

HEDEF (beş ilkeyle yeniden tasarlayın)

Servis firması → VPN → jump server (MFA, kişisel hesap) → bakım DMZ → yalnızca Üretim bölgesi; tam oturum kaydı; modül varsayılan kapalı, onaylı bakım penceresinde süreli açılır. Safety PLC ayrı bölgede, uzak yoldan izole.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   Mevcut tasarımda evet: uzak bakım modülü Safety PLC'ye dijital kesişimle bağlıysa saldırgan ışık perdesi parametrelerini/kapak kilidi mantığını değiştirip koruma zincirini etkisiz kılabilir. Hedefte etkilenmemeli: safety ayrı yolda, uzak yoldan değiştirilemez, ihlalde de el korunur.

2. Işık perdesi zincirinin uzak bakım yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).

   Işık perdesi zinciri, uzak bakım yolu ve normal kontrol sistemi ele geçirilse de çalışmalı: bakım modülüne fiziksel/mantıksal bağlantı yok, safety konfigürasyonuna uzaktan yazma yok (yalnız yerel, yetkili, fiziksel onayla), komut/enerji kaybında güvenli duruma geçiş, değişikliklerin bütünlük kontrolü ve kaydı.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

LABORATUVAR 5 · PAKETPRO 3000 · Paketleme Makinesi

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad	Grup	Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Üç şart: (1) bileşen var: SBOM'da PaketPro Component X (PLC firmware) kayıtlı; (2) sürüm 2.4 CVE'nin etkilenen aralığında mı (bülten/üretici ile doğrula); (3) açık ulaşılabilir mi: uzak bakım modülü internete açık olduğu için büyük olasılıkla evet. Üçü de evetse etkiliyiz.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır. Önce üç şartla gerçek etkiyi doğrularım; kontrolsüz duruş da risktir. Hemen geçici önlem (uzak bakım modülünü kapat/kısıtla), yama için planlı duruş penceresi. Aktif istismar belirtisi veya safety etkisi varsa makineyi güvenli şekilde durdururum.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: üretimden ayrı test PLC'sinde veya yedek/dijital ikiz ortamında denerim. Yedek ve geri dönüş planıyla, bakım penceresinde aşamalı uygularım; doğrudan üretime yama uygulamam.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet etkileyebilir: firmware/kütüphane güncellemesi ışık perdesi/STO fonksiyonunu veya konfigürasyonunu değiştirebilir. Anlamak için üretici sürüm notları, hash/imza ve konfigürasyon karşılaştırması, değişiklik etki analizi; etkileniyorsa safety fonksiyon testi ve yeniden doğrulama.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Erişimi kapatıp sınırlarım: uzak bakım modülünü internetten kaldırma, VPN + jump server + MFA, varsayılan kapalı, ağ segmentasyonu/güvenlik duvarı, ilgili servis ve portu (HMI port 80) devre dışı bırakma, izleme ve alarm, USB kilidi. Geçici, kayıtlı ve yama olana kadar süreli.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · PAKETPRO 3000 · Paketleme Makinesi

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih

Senaryo: Saat **10:15**. PaketPro'nun servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; **ışık perdesi parametreleri henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Vardiya amiri/emniyet sorumlusu, OT/IT güvenlik sorumlusu ve yönetimi ararım. (1) Işık perdesi doğrulanana kadar makineyi güvenli duruma alır, insanı korurum; (2) servis hesabını ve uzak bakım modülünü izole ederim; (3) kanıtı korurum (log, ekran görüntüsü, yedek), PLC'yi resetlemem.

2. **İlk 2 saat:** Egzoz güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Emniyet fonksiyonunu (ışık perdesi, kapak kilidi, STO) test eder, parametreleri bilinen iyi yedekle karşılaştırırım. Korunacak kanıt: PLC, modül, VPN ve güvenlik duvarı logları, 03:00 oturum kayıtları, zaman damgalı yedekler. Servis hesabı kapatılır, parolalar yenilenir.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Olay özeti (03:00'te tanınmayan konumdan servis hesabı girişi, ne zaman fark edildi), etkilenen makine/sürümler, istismar şüphesi (PLC/ışık perdesi parametre değişimi), alınan ilk önlemler, iletişim kişisi. Eksik bilgi sonradan tamamlanır.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (zayıf admin/admin hesap, internete açık modül), etki (PLC/safety parametreleri değişti mi, üretim ve güvenlik), alınan önlem. OT/güvenlik kök nedeni, bakım/emniyet etkiyi ve doğrulamayı, yönetim/uyum bildirimi yapar.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Servis hesabı, uzak bakım modülü, VPN/jump server, güvenlik duvarı ve PLC logları; PLC/ışık perdesi konfigürasyonu önce/sonra yedek ve hash'leri; 03:00 oturum kayıtları; bakım/değişiklik kayıtları; zaman çizelgesi ve alınan aksiyonlar (kanıt zinciri bozulmadan).

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · PAKETPRO 3000 · Paketleme Makinesi

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad	Grup	Tarih

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

*Senaryo: PaketPro'ya YZ'li görsel paket kontrolü **eklenmesi planlanıyor** — proje aşaması değerlendirmesi yapıyorsunuz.*

Kamera → YZ Modeli → OK / RED → Ret mekanizması → Hat hızı

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

   YZ kararı tek başına yetmez: bağımsız ikinci kontrol (ağırlık/ikinci sensör gibi kural tabanlı ölçüm) ve gerekirse insan onayı olmalı. Hatalı OK yakalanırsa paket ayrılır, ret mekanizması devreye girer, hat hızı düşer, kayıt alınır; güvenliği YZ değil Safety PLC mimarisi sağlar.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

   Görüntü kalite/tutarlılık kontrolü, kamera sağlığı ve zaman damgası, ikinci sensörle çapraz kontrol, anomali izleme (monitoring) ile fark edilir. Şüpheli girdide model sonucu kullanılmaz: güvenli duruma (reddet/hat hızını düşür/dur) geçilir, alarm verilir, insan devralır (human override).

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

   Eşik riske göre ve doğrulanarak belirlenir (örn. %95 ve üzeri). Altında otomatik karar yok: önce fallback (paketi reddet/ikinci kontrole al, hat hızını düşür); tekrarlanırsa hat durur ve insana sorulur (human override). Confidence sürekli izlenir.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	Bağımsız ikinci kontrol + insan onayı; şüpheli paket reddedilir, hat hızı düşer (fail-safe, human override).
Girdi manipüle edildi	Girdi doğrulama + monitoring; şüpheli veride modeli kullanma, reddet/yavaşla/dur (fail-safe).
Confidence düştü	Confidence threshold: eşik altında dur / insana sor / fallback (human override).

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.